

Souveraineté et Sécurité des Données

Sécurisation, gouvernance et supervision d'une application web (HealthPredict AI)

Soutenance finale | présentée par KODJO Messanh Yaovi | Date : 11 Juin 2026

TP1 Cartographie | TP2 SQL Injection | TP3 Sécurisation | TP4 Gouvernance

Contexte du projet

Application web traitant des données personnelles, de santé et bancaires

HealthPredict AI

- API Flask + base PostgreSQL + stockage AWS S3
- Authentification d'utilisateurs avec prédiction IA
- Données traitées : identité, santé, bancaire
- Contexte réglementaire : RGPD art. 9 (données sensibles)

Déroulement en 4 TP progressifs

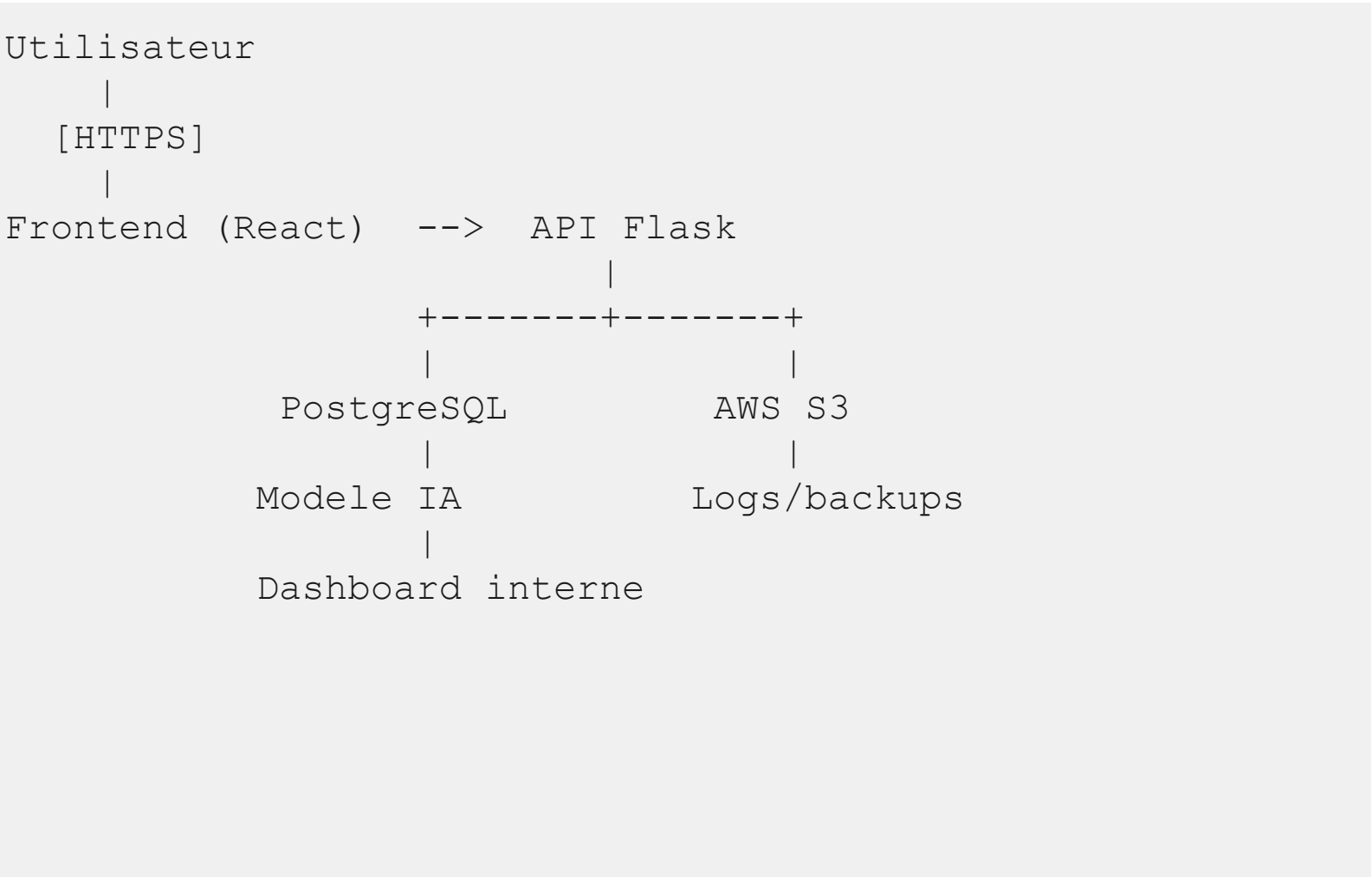
TP	Titre	Objectif
TP1	Cartographie	Identifier les flux et la conformité RGPD
TP2	SQL Injection	Démontrer et comprendre la vulnérabilité
TP3	Sécurisation	Corriger les failles, déployer Grafana
TP4	Gouvernance	Auditer, gouverner, planifier l'amélioration

Fil directeur : d'une application vulnérable à une architecture sécurisée, supervisée et conforme.

TP1 : Cartographie des données

Identification des flux, des acteurs et de la classification RGPD

Flux de données



Classification des données

Categorie	Sensibilite	Risque
Nom, email, adresse	Standard	Usurpation d'identite
Données de santé	Très élevée	Discrimination, chantage
Données bancaires	Élevée	Fraude financière
Logs, adresses IP	Standard	Attaque ciblée

Point clé RGPD : données de santé = catégorie spéciale (art. 9) -> protection renforcée + AIPD obligatoire

Analyse de conformité RGPD

Ecarts identifiés et obligations réglementaires applicables

Exigence RGPD	Article	Etat initial	Action requise
Registre des traitements	Art. 30	Absent	Créer et maintenir le registre
AIPD (données de santé)	Art. 35	Absente	Conduire l'AIPD avant mise en production
Consentement explicite	Art. 7	Non formalise	Checkbox + journalisation
Droit d'accès / effacement	Art. 17	Non implemente	Procédure + interface admin
Chiffrement des donnees	Art. 32	Absent (clair)	Chiffrement AES-256 en base
Notification violation 72h	Art. 33	Pas de procedure	Definir la chaine d'alerte
DPO designe	Art. 37	Non designe	Nommer DPO (interne ou externe)

Niveau de conformite initial : 2/7 critères satisfaits risque juridique élevé en cas de contrôle CNIL

Analyse des risques

Matrice de risque avant sécurisation

Risque	Vraisemblance	Impact	Criticité	Controle initial
Injection SQL	Certaine	Critiqué	CRITIQUE	Aucun
Fuite données santé	Élevée	Critiqué	CRITIQUE	Aucun
Vol de session	Élevée	Élevé	ÉLEVÉ	Absent
Acces non autorisé admin	Élevée	Critique	CRITIQUE	Absent
Perte de données	Moderee	Élevé	ÉLEVÉ	Absent
Attaque par force brute	Certaine	Moderé	ÉLEVÉ	Absent
Défaut de journalisation	Certaine	Moderé	ÉLEVÉ	Absent

3 risques CRITIQUE identifies -> priorité maximale de traitement ; 0 controle en place au depart

TP3 : Mesures de securite mises en oeuvre

Corrections techniques et deploiement de la supervision

Correction 1 — Requetes préparées

```
# AVANT (vulnerable)
query = f"SELECT * FROM users
      WHERE username = '{username}'"

# APRES (securise)
cur.execute(
    "SELECT * FROM users WHERE username = %s",
    (username,)
)
```

Correction 2 — Hachage bcrypt

```
alice2024 -> $2b$12$xK7pL3mN...
Illisible meme en cas de fuite de la base
```

Stack de supervision déployée

```
Flask -> /metrics -> Prometheus -> Grafana
Flask -> app.log -> Promtail -> Loki
PostgreSQL -> pg_exporter -> Prometheus
```

Observabilité en temps reel

- Connexions reussies / echouées (compteurs)
- Débit des tentatives (rate/minute)
- Logs LOGIN_FAILURE avec payloads visibles
- Connexions PostgreSQL actives

Resultat : 6 vecteurs d'attaque TP2 -> tous bloqués (401 Unauthorized)

TP4 : Resultats de l'audit

Audit des logs applicatifs

Traces d'attaque detectées

```
{"event": "LOGIN_FAILURE", "username": "' UNION SELECT 1,'hacker'...", "ip": "172.21.0.1"}
{"event": "LOGIN_FAILURE", "username": "' OR 1=1--", "ip": "172.21.0.1"}
```

Constat	Statut
6 payloads SQL injection — toutes bloquées et journalisées	Conforme
Authentification PostgreSQL via SCRAM-SHA-256	Conforme
Taux d'erreur serveur = 0 %	Conforme
Attaque automatisée : 6 payloads en 716 ms — aucun rate limiting actif	A corriger
Un seul utilisateur DB pour tous les accès — moindre privilège non respecté	A corriger
Absence de HTTPS en production	A corriger

Bilan : sécurité applicative établie ; 3 gaps d'infrastructure à traiter en priorité

TP4 : Gouvernance des données

Structure de responsabilité et regles d'exploitation

Role	Responsabilité principale
Responsable du traitement	Conformité RGPD globale, notification CNIL
DPO	Conseil, contrôle, point de contact CNIL
RSSI	Securite technique, gestion des incidents, audits
Data Owner	Validation des accès, durées de retention
Data Steward	Droits des personnes, qualité des données

Regles opérationnelles

- Minimisation : ne collecter que les données strictement nécessaires
- Chiffrement obligatoire pour toute donnée de santé ou bancaire
- Revue des droits d'accès tous les 3 mois
- Notification CNIL obligatoire sous 72 heures en cas de violation

TP4 : Strategie de sauvegarde et continuité

Règle 3-2-1 et objectifs de reprise

Architecture de sauvegarde (regle 3-2-1)

```
Donnees live    ->  Dump quotidien (02h00)    ->  Archive hebdomadaire (S3)
  [Copie 1]          [Copie 2 - local]          [Copie 3 - hors site]
```

Indicateur	Valeur cible	Signification
RPO (Recovery Point Objective)	24 heures	Perte de données maximale acceptable
RTO (Recovery Time Objective)	4 heures	Delai de remise en service maximum

Points d'attention critiques

- Tests de restauration obligatoires chaque mois une sauvegarde non testée ne garantit rien
- Chiffrement des sauvegardes avant transfert vers S3
- Journalisation de chaque opération de sauvegarde et de restauration
- Alerte automatique en cas d'échec du job de sauvegarde

Recommandations et feuille de route

Plan d'amélioration en 4 phases priorité décroissante

Phase	Echéance	Actions
Phase 1 — Urgence	Semaines 1-2	HTTPS (TLS 1.3) + Rate limiting (5 req/min) + Verrouillage compte (5 échecs)
Phase 2 — Sécurisation	Semaines 3-6	Chiffrement AES-256 en base + Moindre privilege DB + Sauvegardes automatisees
Phase 3 — Conformité	Mois 2-3	Registre RGPD (art. 30) + AIPD + 2FA admin + DPF AWS + DPO nommé
Phase 4 — Amélioration continue	Long terme	Pentest annuel + Formation sécurité + Revue trimestrielle des droits

Principe

La sécurité n'est pas un état final, c'est un processus. Chaque mesure réduit la surface d'attaque mais n'élimine pas tous les risques. L'audit régulier et la supervision continue permettent de maintenir le niveau de protection dans le temps

Conclusion

Ce que ce projet démontre

- Une seule vulnérabilité (injection SQL) suffit à compromettre l'ensemble d'un système
- Les corrections techniques (requêtes préparées, bcrypt)
- La sécurisation ne s'arrête pas au code : supervision, gouvernance et conformité sont indissociables
- L'audit valide que les mesures fonctionnent réellement, pas seulement qu'elles existent

Les trois piliers d'une sécurité durable

Technique	Organisationnel	Reglementaire
Requetes préparées	Gouvernance des données	RGPD art. 30 (registre)
Hachage bcrypt	Rôles et responsabilités	AIPD (art. 35)
HTTPS / TLS	Procedures d'audit	Notification CNIL 72h
Rate limiting	Formation sécurité	DPF / CCT AWS
Supervision Grafana	Tests de restauration	Registre des traitements

Merci pour votre attention

Questions ?